SCIENCE
SCIENTIFIC JOURNAL

Sistema de Avaliação de Maturidade em Segurança Digital para Instituições Educacionais com Base no NIST CSF e LGPD

Digital Security Maturity Assessment System for Educational Institutions Based on NIST CSF and LGPD

Fernanda Holanda

Sandir Campos[3] (Orientador)[3]

Resumo: Instituições educacionais, ao lidarem com dados sensíveis, evidenciam uma baixa maturidade em segurança digital e governança, o que resulta em vulnerabilidade e não conformidade com a Lei Geral de Proteção de Dados (LGPD). Diante deste cenário, a pergunta de pesquisa que norteia este estudo é: como as instituições educacionais podem estruturar um modelo de avaliação de maturidade em segurança digital que atenda às exigências da LGPD e aos padrões do NIST CSF? Propõe-se o desenvolvimento de um modelo simplificado de avaliação da maturidade, fundamentado no NIST CSF e na LGPD, em conjunto com um sistema que inclua um dashboard de indicadores de risco. A metodologia compreende pesquisa bibliográfica, definição de controles específicos para a educação, validação do instrumento junto a gestores e coordenadores pedagógicos de instituições de ensino e implementação de sistema para cálculo de indicadores ponderados. O modelo é submetido a uma validação estruturada por meio de uma aplicação piloto. Objetiva-se identificar vulnerabilidades, mensurar os riscos inerentes e fornecer recomendações práticas, contribuindo para o aprimoramento da governança de segurança digital neste setor.

Palavras-chave: Segurança Digital. NIST. LGPD. Governança. Educação. Validação de Instrumento.

Abstract: Educational institutions, when dealing with sensitive data, show low maturity in digital security and governance, which results in vulnerability and non-compliance with the General Data Protection Law (LGPD). Given this scenario, the research question that guides this study is: how can educational institutions structure a digital security maturity assessment model that meets the requirements of the LGPD and the standards of the NIST CSF? The development of a simplified maturity assessment model is proposed, based on the NIST CSF and the LGPD, along with a system that includes a risk indicator dashboard. The methodology includes bibliographic research, definition of specific controls for education, instrument validation with school managers and pedagogical coordinators, and implementation of a system for calculating weighted indicators. The model is subjected to structured validation through a pilot application. The objective is to identify vulnerabilities, measure inherent risks, and provide practical recommendations, contributing to the improvement of digital security governance in this sector.

Keywords: Digital Security. NIST. LGPD. Governance. Education. Instrument Validation.

Introdução

Atualmente, a internet é indispensável em diversas atividades pedagógicas, o que resulta em um aumento significativo da exposição de estudantes ao ciberespaço e aos seus riscos inerentes (CGI.br, 2023). Nesse cenário, as instituições educacionais tornaram-se responsáveis pelo tratamento de um grande volume de dados pessoais sensíveis, que abrangem desde registros acadêmicos até informações socioeconômicas, entre outros dados críticos. No entanto, muitas dessas organizações ainda operam com uma estrutura limitada de governança em segurança da informação, tornando-as alvos vulneráveis a ameaças cibernéticas contemporâneas.

A conformidade com a Lei Geral de Proteção de Dados (LGPD) impõe a essas instituições a obrigação legal de adotar medidas de segurança e transparência no tratamento de dados (BRASIL, 2018). Paralelamente, o NIST Cybersecurity Framework (CSF) 2.0 oferece uma taxonomia de resultados de alto nível que permite a organizações, independentemente de seu porte ou nível de maturidade, gerenciar e comunicar riscos de cibersegurança (NIST, 2024). Estudos de governança indicam que há uma necessidade crescente de modelos de avaliação de maturidade específicos para o contexto educacional, capazes de identificar lacunas de proteção (CUNHA; FREITAS, 2022).

Enquanto a conformidade com a LGPD é obrigatória, a soberania digital em educação é uma questão estratégica pouco explorada. Instituições educacionais brasileiras dependem crescentemente de plataformas estrangeiras para operações críticas. Este modelo diferencia-se ao permitir a identificação de gaps de soberania, a avaliação de risco geopolítico e o planejamento de autonomia operacional, reduzindo o déficit de governança de TI em ambientes acadêmicos (SANTOS et al., 2025).

Diante da lacuna entre exigências legais e capacidade técnica institucional, este trabalho propõe um modelo simplificado de avaliação de maturidade em segurança digital. O modelo integra os requisitos da LGPD às seis funções centrais do NIST CSF 2.0. Como diferencial, propõe-se a implementação de um sistema computacional capaz de converter respostas de um questionário estruturado em um dashboard visual de indicadores de risco, oferecendo suporte à tomada de decisão.

Referencial Teórico

Nos últimos anos, houve um aumento significativo na adoção de tecnologias em escolas e universidades, abrangendo atividades educacionais e administrativas, o que resultou em um incremento na quantidade de dados sensíveis (FERREIRA et al., 2023). Apesar das vantagens oferecidas por essa transformação, surgiram novos perigos. Instituições de ensino continuam a ser alvos frequentes, com casos recentes de sequestros de dados e vazamentos de informações. Uma parte considerável ainda carece de infraestrutura de segurança adequada, tornando-se suscetível a ameaças como phishing e vulnerabilidades em sistemas (RANI, 2025).

O setor educacional figura entre os alvos mais vulneráveis e frequentemente atacados no panorama global de cibersegurança. De acordo com relatórios setoriais recentes, instituições de ensino sofreram centenas de incidentes de segurança no Brasil entre 2023 e 2024, com parcela significativa envolvendo exposição indevida de dados pessoais de estudantes (MACHERTECNOLOGIA, 2024). Essa vulnerabilidade se intensifica pelo fato de que as bases de dados educacionais concentram informações de elevada sensibilidade — registros acadêmicos, dados de saúde, informações financeiras e documentos de identificação de menores —, tornando-as um ativo valioso para agentes maliciosos em fóruns da deep web.

No contexto brasileiro, a Autoridade Nacional de Proteção de Dados (ANPD) incluiu expressamente o "tratamento de dados pessoais de crianças e adolescentes no ambiente digital" como eixo prioritário de fiscalização para o biênio 2024-2025 (ANPD, 2024). Em 2024, a autoridade aplicou sanções a órgãos públicos decorrentes da exposição de dados sensíveis de 3.030 crianças e adolescentes, incluindo informações de saúde, em razão de configuração inadequada de formulário digital. As irregularidades apontadas incluíram a

ausência de Registro de Operações de Tratamento (ROPA), a inexistência de Relatório de Impacto à Proteção de Dados (RIPD) e a comunicação tardia aos titulares dos dados (MAYER BROWN, 2024).

Um caso emblemático no âmbito federal foi o incidente com o Sistema de Seleção Unificada (Sisu) em 2024, quando o Ministério da Educação (MEC) admitiu a "divulgação indevida de resultados provisórios", evidenciando os riscos inerentes a plataformas que processam dados de milhões de estudantes em larga escala (METRÓPOLES, 2024). Episódios dessa natureza reforçam a urgência de que as instituições de ensino adotem modelos estruturados de avaliação de maturidade em segurança da informação, capazes de identificar lacunas antes que estas se convertam em incidentes formalmente reportáveis.

A proteção destes dados é pautada por legislações como a LGPD no Brasil, que dispõe princípios como transparência e segurança (BRASIL, 2018). A implementação da LGPD em instituições de ensino exige adaptações sistêmicas rigorosas, frequentemente dificultadas pela falta de mapeamento adequado dos fluxos de informação (GNOCCATO; SILVA, 2022). As consequências do descumprimento são severas: o art. 52 da LGPD prevê sanções que incluem multa simples de até 2% do faturamento anual da pessoa jurídica, limitada a R$ 50.000.000,00 (cinquenta milhões de reais) por infração, multa diária, publicização da infração e determinação de bloqueio ou eliminação dos dados — penalidades aplicadas de forma gradativa pela ANPD, considerando a gravidade da infração, a boa-fé do controlador e o grau do dano causado aos titulares (BRASIL, 2018). A lei, em seu Artigo 14, estabelece o rigor no tratamento de dados de crianças e adolescentes, exigindo o consentimento específico e em destaque por pelo menos um dos pais ou responsável legal, operando em conjunto com as diretrizes de proteção integral do Estatuto da Criança e do Adolescente (BRASIL, 1990).

A fundamentação teórica da segurança da informação repousa sobre a Tríade CIA — Confidencialidade, Integridade e Disponibilidade —, que estabelece os três objetivos essenciais que qualquer sistema seguro deve garantir. A Confidencialidade assegura que as informações sejam acessadas apenas por indivíduos autorizados; a Integridade garante que os dados permaneçam precisos e livres de modificações não autorizadas; e a Disponibilidade assegura que os sistemas e informações estejam acessíveis quando necessários pelos usuários legítimos (NIST, 2024). Complementarmente, o princípio da Defesa em Profundidade (Defense in Depth) determina que a proteção deve ser estruturada em múltiplas camadas sobrepostas de controles — físicos, técnicos e administrativos — eliminando pontos únicos de falha: se uma camada é comprometida, as demais mantêm a segurança do sistema. No contexto educacional, a Tríade CIA orienta a proteção de registros acadêmicos e dados de menores contra divulgação não autorizada (Confidencialidade), a preservação da integridade de históricos e boletins digitais (Integridade) e a continuidade de plataformas de gestão escolar e e-learning (Disponibilidade). A operacionalização da Tríade CIA pressupõe a adoção de uma taxonomia formal de classificação da informação, que permite proteção diferenciada conforme a criticidade dos dados ao longo de todo o seu ciclo de vida — manuseio, armazenamento, transmissão e descarte. Em instituições educacionais, essa taxonomia deve contemplar ao menos três níveis: (1) Alta confidencialidade — notas, históricos médicos, dados financeiros de responsáveis e registros disciplinares de alunos, cujo vazamento impacta diretamente direitos fundamentais e pode ensejar sanções da ANPD; (2) Confidencialidade moderada — dados de matrícula, frequência e registros pedagógicos, de

acesso restrito ao corpo funcional autorizado; e (3) Confidencialidade baixa — listas de docentes, calendários e informações disponíveis ao público. Sem essa taxonomia, a instituição incorre no erro de proteger dados de baixo valor com a mesma intensidade que registros sensíveis de menores, desperdiçando recursos técnicos e administrativos escassos (NIST, 2024).

O NIST Cybersecurity Framework (CSF), publicado originalmente em 2014 pelo Instituto Nacional de Padrões e Tecnologia dos Estados Unidos (National Institute of Standards and Technology), foi concebido como uma abordagem voluntária, flexível e baseada em riscos para a gestão da cibersegurança organizacional. Em fevereiro de 2024, o NIST publicou a versão 2.0 do framework — um marco significativo que introduziu a função "Govern" (Governar) às cinco funções originais (Identificar, Proteger, Detectar, Responder e Recuperar), elevando o papel da liderança institucional na estratégia de segurança (NIST, 2024).

Um aspecto metodológico fundamental que este trabalho explicita é a distinção entre os **Tiers (Níveis de Implementação)** do NIST CSF e um **Modelo de Maturidade de Capacidade (CMM)** tradicional. Os Tiers do NIST CSF (Parcial, Risco Informado, Repetível e Adaptável) têm por objetivo caracterizar o rigor das práticas de gestão de risco de uma organização, e não prescrever um caminho linear de progressão como um CMM convencional (SCF, 2025). A ausência de critérios objetivos e autoritativos para cada Tier — diferentemente do que ocorre em modelos como o CMMC ou o SSE-CMM — cria uma dependência da ética e do julgamento do avaliador, o que pode introduzir subjetividade nos diagnósticos (SCF, 2025). Por essa razão, o presente modelo adota uma escala de maturidade própria de 4 níveis (Inicial, Intermediário, Gerenciado e Otimizado), com critérios objetivos por controle, utilizando os Tiers apenas como referência de contexto organizacional, e não como unidade de medição direta.

Para as instituições educacionais, o NIST CSF 2.0 apresenta relevância particular em razão de sua natureza não prescritiva, que permite adaptações às realidades de organizações com recursos humanos e orçamentários limitados — característica comum em escolas e faculdades de médio porte no contexto brasileiro (OCD-TECH, 2024). A função Identify orienta o mapeamento completo de ativos digitais, incluindo sistemas de gestão acadêmica, plataformas de e-learning e repositórios de dados de alunos. A função Protect direciona a implementação de salvaguardas como autenticação multifator, criptografia de dados em repouso e Controle de Acesso Baseado em Papéis (RBAC — Role-Based Access Control). O RBAC é especialmente adequado para instituições educacionais em razão da alta rotatividade semestral de alunos, docentes e funcionários: permissões são atribuídas a papéis institucionais (ex: "Aluno", "Docente", "Secretaria Acadêmica") e os acessos são automaticamente provisionados ou revogados conforme o vínculo com a instituição, eliminando o risco de "contas órfãs" e viabilizando a Segregação de Funções (SoD). Complementarmente, a segmentação lógica de rede por meio de VLANs — isolando a rede de alunos dos servidores acadêmicos e financeiros — contém o movimento lateral de ameaças e reduz o raio de impacto (blast radius) de eventuais comprometimentos (NIST, 2024). As funções Detect e Respond estabelecem os pilares para a criação de um plano de resposta a incidentes — uma exigência legal expressa da LGPD em seu art. 48, que determina ao controlador comunicar à ANPD e aos titulares a ocorrência de incidentes de segurança que possam acarretar risco ou

dano relevante no prazo de 3 (três) dias úteis, contado a partir do conhecimento do evento, conforme a Resolução CD/ANPD Nº 15/2024 (ANPD, 2024). A função Recover, por sua vez, garante a continuidade das atividades pedagógicas mesmo em cenários de comprometimento sistêmico (CAMPUSWORKS, 2024; NIST, 2024). A operacionalização dessas funções ocorre por meio de um ciclo formal de resposta a incidentes, composto por seis fases sequenciais: (1) Preparação — elaboração do plano de resposta, definição de papéis e implantação de controles preventivos; (2) Detecção e Análise — monitoramento contínuo com ferramentas como SIEM e IDS para confirmar a ocorrência de incidentes reais frente a falsos positivos; (3) Contenção — isolamento imediato da ameaça para impedir o movimento lateral na rede, preservando evidências forenses; (4) Erradicação — remoção definitiva da causa raiz, incluindo desativação de contas comprometidas e exclusão de malware; (5) Recuperação — restauração dos sistemas a partir de backups verificados e retorno monitorado à produção; e (6) Lições Aprendidas — análise pós-incidente com identificação da causa raiz para retroalimentar e fortalecer a fase de Preparação (NIST, 2024).

A função "Govern", recém-introduzida na versão 2.0, é especialmente relevante para instituições acadêmicas, pois endereça a necessidade de que a cibersegurança deixe de ser percebida como uma responsabilidade exclusiva das equipes de Tecnologia da Informação (TI) e passe a integrar a agenda estratégica da alta gestão — diretores, reitores e conselhos administrativos (CYBERSECURITY RUBRIC, 2024). A adoção do NIST CSF no setor educacional brasileiro encontra respaldo na literatura internacional recente: Lund (2024) demonstrou sua aplicabilidade em instituições de ensino superior; Rani (2025) propôs um framework gamificado derivado do NIST CSF especificamente para a educação em cibersegurança; e Zakharova e Partyka (2025) analisaram sua evolução como instrumento de gestão de riscos cibernéticos.

A proteção de dados pessoais de crianças e adolescentes no ambiente escolar é regida pela confluência de dois marcos normativos complementares: a Lei Geral de Proteção de Dados Pessoais (LGPD — Lei nº 13.709/2018) e o Estatuto da Criança e do Adolescente (ECA — Lei nº 8.069/1990). Essa convergência não é acidental; a própria LGPD, em seu art. 14, utiliza as definições etárias do ECA para delimitar as categorias de titulares com proteção reforçada: crianças (até 12 anos incompletos) e adolescentes (entre 12 e 18 anos) (BRASIL, 1990; BRASIL, 2018).

O princípio unificador dessas legislações é o Princípio do Melhor Interesse do Menor, que determina que qualquer tratamento de dados pessoais de crianças e adolescentes deve ser realizado com o objetivo precípuo de proteger e promover o bem-estar integral do titular, jamais subordinando-o a interesses comerciais ou operacionais da controladora (LGPD, art. 14, caput). No ambiente escolar, as instituições de ensino atuam na qualidade de controladoras de dados, cabendo-lhes adotar medidas técnicas e administrativas para prevenir acessos não autorizados, garantir a transparência com pais e responsáveis sobre as finalidades do tratamento e assegurar a segurança de registros sensíveis como boletins, laudos psicológicos, dados de saúde e informações disciplinares (OAB CAMPINAS, 2024).

Um avanço normativo relevante ocorreu com a promulgação do chamado "ECA Digital" (Lei nº 14.811/2024), que introduziu salvaguardas específicas para produtos e serviços de tecnologia da informação direcionados ao público infantojuvenil. O diploma exige a adoção de segurança por design (Privacy by Design) — princípio segundo o qual os

sistemas devem ser projetados com os mais elevados padrões de privacidade desde a sua concepção —, além de mecanismos de prevenção ao uso inadequado por menores (PLANALTO, 2024). Essa exigência é de especial relevância para sistemas de gestão escolar, plataformas de e-learning e aplicativos de comunicação entre escola e família, que processam cotidianamente volumes expressivos de dados de titulares menores de 18 anos.

A ANPD, em seu Enunciado CD/ANPD nº 01/2023, uniformizou a interpretação de que todas as bases legais previstas nos artigos 7º e 11 da LGPD podem ser aplicadas ao tratamento de dados de menores, desde que o Princípio do Melhor Interesse seja rigorosamente observado (ANPD, 2023). Isso significa que o consentimento parental, embora seja a base legal mais frequentemente empregada para crianças, não é a única possibilidade: o legítimo interesse e a execução de políticas públicas também podem fundamentar o tratamento, desde que compatíveis com a proteção integral do menor.

No que concerne à governança de dados, a LGPD determina, em seu art. 41, que o controlador deve indicar formalmente um Encarregado pelo Tratamento de Dados Pessoais (DPO — Data Protection Officer), que atua como canal de comunicação entre a instituição, os titulares dos dados e a ANPD (ANPD, 2023). No contexto educacional, o Encarregado exerce funções centrais: aceitar reclamações e comunicações de alunos, pais e responsáveis, prestando-lhes os devidos esclarecimentos; receber comunicações da ANPD e adotar as providências cabíveis; orientar funcionários e contratados sobre as práticas de proteção de dados; e auxiliar na elaboração do Relatório de Impacto à Proteção de Dados Pessoais (RIPD), instrumento obrigatório nos tratamentos classificados como de alto risco — categoria que inclui expressamente o tratamento de dados de crianças e adolescentes (BRASIL, 2018). A designação formal de um Encarregado representa, portanto, um controle administrativo de maturidade indispensável em qualquer modelo de governança de segurança digital para o setor educacional.

Para viabilizar a adequação tecnológica e a proteção desses dados, a adoção de frameworks globais é fundamental. O NIST CSF 2.0 está no topo da lista de referências, organizado em funções de governança: identificar, proteger, detectar, responder, recuperar e governar (NIST, 2024). A evolução do gerenciamento de riscos cibernéticos através do prisma do NIST tem se mostrado eficaz para avaliar a maturidade das entidades educacionais (ZAKHAROVA; PARTYKA, 2025).

A complementaridade entre frameworks de segurança é um aspecto central para uma governança abrangente. A norma ISO/IEC 27001 define os requisitos para estabelecer, implementar, operar, monitorar e melhorar continuamente um Sistema de Gestão de Segurança da Informação (SGSI), estruturado no ciclo Plan-Do-Check-Act (PDCA) e reconhecido internacionalmente como o padrão de referência para conformidade e certificação em segurança da informação (ISO/IEC 27001, 2022). A relação entre o NIST CSF 2.0 e a ISO 27001 é de complementaridade: enquanto o NIST organiza os resultados esperados em funções de alto nível orientadas ao risco, a ISO 27001 fornece o sistema de gestão necessário para operacionalizar esses controles de forma auditável e certificável. No âmbito da governança de TI, o COBIT (Control Objectives for Information and Related Technologies) oferece um modelo para alinhar os objetivos tecnológicos às metas estratégicas institucionais, sendo especialmente relevante para instituições educacionais que precisam demonstrar e justificar seus investimentos em segurança perante conselhos administrativos e

órgãos reguladores (ISACA, 2019). A concretização dessa governança requer a elaboração de uma Política de Segurança da Informação (PSI), pedra angular normativa do programa de proteção institucional, estruturada em três camadas hierárquicas: (1) Estratégica — diretrizes e declaração de compromisso da alta gestão com a proteção de dados; (2) Tática — normas específicas por domínio, abrangendo senhas, uso aceitável, tratamento de dados de menores e resposta a incidentes; e (3) Operacional — procedimentos e instruções passo a passo destinados às equipes de TI e usuários finais (ISO/IEC 27001, 2022). Uma PSI clara, aprovada pela direção e compreensível a todos os atores da comunidade escolar, transforma a cultura organizacional e reduz incidentes originados pelo fator humano — vetor predominante em violações de segurança.

Além disso, estratégias modernas como Zero Trust enfatizam a necessidade de não confiar automaticamente em acessos, particularmente em ambientes de uso de dispositivos pessoais e serviços em nuvem (PECK, 2021). A integração desses frameworks com a conformidade jurídica, especialmente nas fases críticas de mapeamento, tem se mostrado o maior desafio para os profissionais de TIC nas instituições de ensino (SILVA; SARKIS, 2023).

A dependência crescente de plataformas de terceiros — como Google Workspace for Education, Microsoft 365, sistemas de gestão escolar SaaS e demais EdTechs — representa uma dimensão crítica e frequentemente negligenciada na avaliação de maturidade institucional. O NIST CSF 2.0 endereça explicitamente a Gestão de Riscos da Cadeia de Suprimentos Cibernética (C-SCRM — Cyber Supply Chain Risk Management) na função Govern (GV.SC), determinando que as organizações avaliem a postura de segurança dos seus fornecedores de tecnologia (NIST, 2024). No âmbito do ensino superior, o Higher Education Community Vendor Assessment Toolkit (HECVAT), desenvolvido pela EDUCAUSE, tornou-se o instrumento de referência para avaliar a segurança de fornecedores de soluções em nuvem e EdTechs antes da contratação, verificando a compatibilidade das práticas do fornecedor com os requisitos da LGPD e os padrões NIST (EDUCAUSE, 2019). A ausência de processos formais de avaliação de fornecedores representa uma lacuna crítica de maturidade: ao contratar uma nova plataforma de ensino sem diligência prévia, a instituição pode inadvertidamente "importar" riscos que comprometem dados de alunos menores — responsabilidade legal que não é transferida ao fornecedor pelo simples ato da contratação.

Metodologia

O escopo deste estudo é prático, com uma abordagem qualitativa e quantitativa, visando à elaboração de um modelo de avaliação da maturidade em segurança digital para instituições de ensino. Inicialmente, foi realizada uma revisão da literatura com base em estruturas de cibersegurança, como o NIST CSF 2.0, e legislações vigentes, principalmente a LGPD.

Os controles foram selecionados e estruturados em uma matriz com 3 dimensões. A Dimensão 1 engloba o Tipo de Controle, estruturado em dois eixos complementares: a Categoria de implementação (Técnico, Administrativo e Físico) e o Tipo funcional — Preventivo (atua antes do incidente para reduzir a probabilidade do ataque), Detectivo (identifica e registra anomalias durante ou após a ocorrência) e Corretivo (elimina ou minimiza o impacto após a violação). Essa dupla classificação permite que o modelo avalie

tanto a completude das salvaguardas instaladas quanto a cobertura temporal do ciclo de segurança, alinhando-se à Tríade CIA e às funções do NIST CSF 2.0 (NIST, 2024). A Dimensão 2 abrange o Contexto Educacional: Dados de Menores com proteção reforçada (ANPD, 2022), Dados Acadêmicos, Dados Sensíveis e Dados de Pesquisa. A Dimensão 3 foca no Nível de Implementação (Maturidade), variando de Nível 1 (Inicial) a Nível 4 (Otimizado).

Para exemplificar a estrutura adotada, a Tabela 1 apresenta um recorte da matriz simplificada desenvolvida para a avaliação:

Tabela 1 – Matriz Simplificada de Controles de Segurança Digital para Instituições Educacionais

Controle NIST	**Categoria**	**Contexto Educacional**	**Nível de Maturidade**
ID.AM-1: Inventário de Hardware	Administrativo	Dados Acadêmicos	Nível 1 (Inicial)
PR.AC-1: Gerenciamento de Identidade	Técnico	Dados Sensíveis	Nível 2 (Intermediário)
PR.DS-1: Proteção de Dados em Repouso	Técnico	Dados de Menores	Nível 3 (Gerenciado)
DE.CM-1: Monitoramento de Rede	Técnico	Dados de Pesquisa	Nível 4 (Otimizado)
RS.RP-1: Plano de Resposta a Incidentes	Administrativo	Todos os Dados	Nível 2 (Intermediário)

Fonte: Elaborado pelos autores (2026).

A partir dessa matriz, um questionário estruturado foi desenvolvido, permitindo que instituições auto-avaliem seu nível de maturidade. O modelo calcula indicadores ponderados, incluindo o Score de Maturidade Geral, o Score por Função NIST, e um indicador inovador denominado Risk Score para Dados de Menores (RSDM), focado na proteção reforçada exigida pela LGPD e ECA. A estrutura de cálculo dos indicadores ponderados alinha-se às diretrizes de medição e avaliação da eficácia do SGSI preconizadas pela norma ISO/IEC 27004 (ISO/IEC 27004, 2016), que orienta o desenvolvimento de programas de métricas de segurança da informação comparáveis e reproduzíveis.

Protocolo de Validação do Instrumento

A fim de garantir o rigor científico do sistema de avaliação, o protocolo de validação compreende quatro etapas complementares, executadas antes da aplicação piloto nas instituições selecionadas.

Etapa 1 — Validação com Gestores Educacionais. Os itens do questionário são submetidos à avaliação de gestores e coordenadores pedagógicos de instituições de ensino, que verificam se as perguntas refletem a realidade operacional das escolas. Questões consideradas pouco relevantes ou de difícil compreensão são reformuladas ou eliminadas antes da aplicação definitiva.

Etapa 2 — Teste de Consistência do Questionário. O questionário é aplicado em um grupo reduzido de instituições para verificar se as respostas relacionadas ao mesmo tema são coerentes entre si. Eventuais inconsistências indicam a necessidade de revisar a redação dos itens antes da aplicação em larga escala.

Etapa 3 — Avaliação de Usabilidade. Gestores escolares sem formação técnica em segurança digital testam o sistema e indicam se o processo é claro e prático. O objetivo é garantir que qualquer profissional da administração escolar consiga conduzir a avaliação sem necessidade de apoio especializado.

Etapa 4 — Verificação dos Resultados. Para evitar que as instituições superestimem sua própria maturidade, as respostas do questionário são confrontadas com documentos e registros internos disponíveis — como políticas de uso, contratos de serviços e registros de ocorrências —, garantindo maior fidelidade ao cenário real da instituição.

Um sistema foi idealizado para converter os resultados em visualizações gráficas através de quatro dashboards distintos (Gestor, Técnico, Operacional e Conselheiro). O modelo prevê uma validação estruturada em 5 fases com 3 instituições educacionais (Seleção, Baseline, Intervenção, Post-Assessment e Refinamento), acompanhada da proposição de roadmaps realistas de 24 meses para implementação em escolas pequenas e universidades.

Resultados e Discussão

Esta pesquisa propõe um design metodológico validado conceitualmente, preparando o terreno para a aplicação empírica. A estruturação do modelo revela que é possível criar uma ponte operacional entre a complexidade normativa da LGPD e os requisitos técnicos do NIST CSF 2.0. Ao integrar a visão de gestão de TI nas universidades (SANTOS et al., 2025) com a necessidade urgente de adequação à LGPD (GATTO et al., 2025), o modelo responde diretamente à pergunta de pesquisa, oferecendo um caminho prático e estruturado para gestores educacionais.

A arquitetura do modelo materializa os conceitos teóricos em métricas avaliáveis. A taxonomia de classificação da informação é operacionalizada na Dimensão 2 da matriz, garantindo que controles aplicados a dados de Alta confidencialidade (ex: laudos médicos de alunos) tenham maior peso no cálculo final, refletindo a Tríade CIA. No âmbito administrativo, a presença formal de um DPO (Art. 41) e a implementação de uma PSI em três camadas são convertidas em requisitos mandatórios na função Govern. Tecnicamente, a adoção de RBAC e a segmentação via VLANs são avaliadas na função Protect, enquanto as seis fases do ciclo de resposta a incidentes orientam os requisitos da função Respond. A gravidade das sanções do Art. 52 da LGPD (com multas de até 2% do faturamento)

fundamenta a calibragem e o peso majorado atribuído ao Risk Score para Dados de Menores (RSDM), que verifica o consentimento parental (Art. 14) e a adesão ao Privacy by Design.

Para demonstrar a aplicabilidade do artefato, realizou-se uma simulação com dados hipotéticos de uma escola de ensino básico de médio porte ("Escola Fictícia Alpha"). Na simulação, a instituição obteve um Score de Maturidade Geral de 2,4 (em uma escala de 1 a 4), situando-se entre os níveis Inicial e Intermediário. A análise por função do NIST revelou: Identify (2,8), Protect (2,5), Detect (1,5), Respond (1,2), Recover (2,0) e Govern (2,2). O baixo desempenho em detecção e resposta indica uma postura reativa, comum no setor, evidenciando vulnerabilidades críticas face a incidentes. O RSDM resultou em "Alto Risco", impulsionado pela ausência de consentimento granular para tratamento de dados de alunos menores.

Estes resultados são traduzidos em quatro dashboards direcionados: o Dashboard do Gestor consolida o Score Geral, o RSDM e o gap de conformidade com a LGPD, servindo para justificar orçamentos; o Dashboard Técnico detalha as falhas em controles específicos (ex: falta de MFA ou VLANs); o Dashboard Operacional mapeia as tarefas diárias e a prontidão de resposta a incidentes; e o Dashboard do Conselheiro foca no alinhamento estratégico e na soberania digital. A inclusão do RSDM preenche uma lacuna acadêmica, superando abordagens genéricas de conformidade (ANPD, 2022) e contrastando com frameworks focados puramente em educação cibernética gamificada, como o proposto por Rani (2025), ao oferecer pragmatismo frente à regulação. A abordagem corrobora as análises de Zakharova e Partyka (2025) sobre a evolução do gerenciamento de riscos cibernéticos, provando que o NIST CSF pode ser adaptado sem perda de rigor metodológico.

O protocolo de validação estabelecido prevê critérios práticos a serem verificados na execução piloto, envolvendo avaliação direta por gestores educacionais, testes de consistência em instituições piloto e verificação dos resultados frente a registros internos reais. A Tabela 3 sintetiza essas etapas e seus respectivos critérios de aprovação.

Tabela 3 – Critérios de Validação do Instrumento de Avaliação de Maturidade

Etapa	**Ação**	**Critério de Aprovação**
Validação com Gestores Educacionais	Avaliação dos itens por gestores e coordenadores pedagógicos	Perguntas consideradas claras e relevantes pela maioria dos avaliadores
Teste de Consistência	Aplicação piloto em grupo reduzido de instituições	Respostas de itens relacionados são coerentes entre si
Avaliação de Usabilidade	Teste com gestores sem formação técnica em segurança digital	Sistema considerado prático e utilizável de forma autônoma
Verificação dos Resultados	Confronto das respostas com	Respostas alinhadas com a

	documentos e registros internos da instituição	realidade documental da instituição
Refinamento do Instrumento	Revisão após cada ciclo de validação	Itens que gerem dúvidas são revisados antes da aplicação definitiva

Fonte: Elaborado pelos autores (2026).

O modelo prova ser tecnicamente viável através da geração de roadmaps priorizados. A Tabela 2 apresenta uma simulação de roadmap comparativo, diferenciando os esforços de acordo com a complexidade da infraestrutura institucional.

Tabela 2 – Roadmap de Implementação Simulado para Instituições Educacionais

Fase (Prazo)	**Escola (Pequeno/Médio Porte)**	**Universidade (Grande Porte)**
Curto Prazo (0–6 meses)	MFA; Nomeação de DPO; PSI Estratégica	Mapeamento de dados (ROPA); VLANs; MFA global
Médio Prazo (6–18 meses)	RBAC; Adequação consentimento Art. 14; Treinamentos	Automação de SOC; Zero Trust inicial; Avaliação HECVAT de fornecedores
Longo Prazo (18–24+ meses)	Testes de IR (6 fases); Monitoramento básico	Certificação ISO 27001; Inteligência de ameaças

Fonte: Elaborado pelos autores (2026).

Apesar dos avanços teóricos e metodológicos, o estudo apresenta limitações inerentes ao seu estágio de desenvolvimento. A limitação primordial é a ausência da coleta de dados empíricos, aguardando a execução da validação piloto para confirmar a adequação e consistência do instrumento de pesquisa. Além disso, o modelo está sujeito ao **viés de autorrelato** — as instituições podem superestimar sua própria maturidade ao responderem ao questionário, especialmente em domínios técnicos em que os respondentes possuem baixa literacia em cibersegurança (RENAUD; WEIR, 2016); esse viés é mitigado pelo protocolo de triangulação descrito na metodologia, mas não pode ser eliminado completamente sem auditoria externa independente. O escopo da pesquisa também é restrito ao contexto normativo brasileiro (LGPD/ECA), necessitando de adaptações para aplicação internacional. O sistema de pontuação precisará de revisões periódicas frente à evolução regulatória e eventuais novas diretrizes da ANPD. Adicionalmente, é importante ressaltar que os **Tiers do NIST CSF 2.0 não constituem um Modelo de Maturidade de Capacidade (CMM) tradicional** — a ausência de critérios objetivos por Tier impede sua utilização direta como escala de avaliação, justificando a adoção de uma escala de 4 níveis com critérios explícitos no presente modelo (SCF, 2025). Por fim, o escopo da avaliação está centrado no perímetro

institucional, ainda que o modelo preveja a dimensão de gestão de fornecedores; a validação completa do componente C-SCRM/HECVAT exigirá a participação ativa dos fornecedores de EdTechs contratados pelas instituições piloto, o que representa uma variável de controle adicional.

Considerações Finais

Este trabalho apresenta um modelo teórico-prático para avaliação de maturidade em segurança digital em instituições educacionais. O modelo diferencia-se pela integração metodológica da LGPD e do NIST CSF, pelo foco na soberania digital, pela introdução do indicador exclusivo RSDM para monitoramento de dados infantis e pelo protocolo estruturado de validação do instrumento, conduzido com gestores educacionais e testado diretamente nas instituições.

A adoção do sistema de dashboards e da matriz de controles (conforme delineado na Tabela 1) permite que as instituições saiam de um estado de inércia ou confusão normativa para uma postura de gestão ativa de riscos. Recomenda-se a utilização deste framework como padrão de referência para o setor educacional, facilitando a adequação à LGPD por meio de métricas visuais e compreensíveis.

Para trabalhos futuros, planeja-se a execução do protocolo de validação piloto com as três instituições selecionadas, o que fornecerá os dados empíricos necessários para confirmar os critérios de validação e refinar o algoritmo de cálculo dos scores. Adicionalmente, vislumbra-se o desenvolvimento de um software que automatize inteiramente a geração dos dashboards a partir da coleta das respostas, bem como a extensão do modelo para cobrir integralmente a dimensão C-SCRM com aplicação do HECVAT junto aos fornecedores de EdTechs contratados pelas instituições avaliadas.

Referências

ANPD – AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. Enunciado CD/ANPD nº 01/2023: Tratamento de dados pessoais de crianças e adolescentes. Brasília: ANPD, 2023. Disponível em: https://www.gov.br/anpd. Acesso em: 23 abr. 2026.

ANPD – AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. Agenda Regulatória 2024-2025. Brasília: ANPD, 2024. Disponível em: https://www.gov.br/anpd. Acesso em: 23 abr. 2026.

ANPD - Autoridade Nacional de Proteção de Dados. Guia Orientativo: Tratamento de Dados Pessoais de Crianças e Adolescentes. Brasília: ANPD, 2022.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 2018.

BRASIL. Lei nº 14.811, de 12 de janeiro de 2024. Institui medidas de proteção de crianças e adolescentes em plataformas digitais. Brasília: Presidência da República, 2024. Disponível em: https://www.planalto.gov.br. Acesso em: 23 abr. 2026.

BRASIL. Lei nº 8.069, de 13 de julho de 1990. Estatuto da Criança e do Adolescente (ECA). Diário Oficial da União, Brasília, DF, 1990.

CAMPUSWORKS INC. Implementing NIST CSF 2.0 in higher education: a practical guide. 2024. Disponível em: https://campusworksinc.com. Acesso em: 23 abr. 2026.

CGI.br - Comitê Gestor da Internet no Brasil. Pesquisa sobre o uso das tecnologias de informação e comunicação nas escolas brasileiras: TIC Educação. São Paulo: CGI.br, 2023.

CUNHA, P. da S.; FREITAS, M. A. L. de. Governança corporativa e governança de TI nas universidades federais brasileiras. Revista FSA, v. 19, n. 10, 2022.

CYBERSECURITY RUBRIC. NIST Cybersecurity Framework 2.0 in Higher Education: governance and leadership integration. 2024. Disponível em: https://www.cybersecurityrubric.org. Acesso em: 23 abr. 2026.

EDUCAUSE. Higher Education Community Vendor Assessment Toolkit (HECVAT). Louisville: EDUCAUSE, 2019. Disponível em: https://www.educause.edu/hecvat. Acesso em: 23 abr. 2026.

FERREIRA, R. V. B.; FREITAS, B. P. T.; LAZARIN, N. M. Uma abordagem para gestão de cenários no ensino de Segurança de Sistemas de Informação. In: SIMPÓSIO BRASILEIRO DE SEGURANÇA DA INFORMAÇÃO E DE SISTEMAS COMPUTACIONAIS (SBSEG), 23., 2023. Anais Estendidos [...]. 2023.

GATTO, D.; PORTELLADA, N.; SASSI, R. J. Identificação de pontos críticos em processo de adequação à LGPD em instituição de ensino infantil e médio. In: SIMPÓSIO DE ENGENHARIA DE PRODUÇÃO (SIMPEP), 31., 2025. Anais [...]. v. 1. 2025.

GNOCCATO, A. R.; SILVA, R. L. da. Implementação da LGPD em instituições de ensino privadas de Santa Maria: panorama dos sites institucionais. In: SIMPÓSIO DE ENSINO, PESQUISA E EXTENSÃO (SEPE), 2022. Anais [...]. 2022.

ISACA. COBIT 2019 Framework: Introduction and Methodology. Rolling Meadows: ISACA, 2019. Disponível em: https://www.isaca.org/resources/cobit. Acesso em: 23 abr. 2026.

ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Geneva: ISO, 2022. Disponível em: https://www.iso.org/standard/27001. Acesso em: 23 abr. 2026.

ISO/IEC 27004:2016. Information technology — Security techniques — Information security management — Monitoring, measurement, analysis and evaluation. Geneva: ISO, 2016. Disponível em: https://www.iso.org/standard/64120.html. Acesso em: 23 abr. 2026.

LUND, B. Blockchain applications in higher education based on the NIST Cybersecurity Framework. Journal of Cybersecurity Education, Research and Practice, v. 2024, n. 1, 2024.

MACHER TECNOLOGIA. Cenário de cibersegurança no setor educacional brasileiro: incidentes e tendências 2023–2024. 2024. Disponível em: https://www.machertecnologia.com.br. Acesso em: 23 abr. 2026.

MAYER BROWN. ANPD sanctions public agency for exposure of children's health data: 3,030 records affected. 2024. Disponível em: https://www.mayerbrown.com. Acesso em: 23 abr. 2026.

METRÓPOLES. MEC admite divulgação indevida de resultados provisórios do Sisu 2024. Brasília: Metrópoles, 2024. Disponível em: https://www.metropoles.com. Acesso em: 23 abr. 2026.

NIST – NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. NIST Cybersecurity Framework 2.0. Gaithersburg: NIST, 2024. Disponível em: https://doi.org/10.6028/NIST.CSWP.29. Acesso em: 23 abr. 2026.

OAB CAMPINAS. LGPD nas instituições de ensino: responsabilidades das controladoras de dados pessoais. Campinas: OAB, Subseção Campinas, 2024. Disponível em: https://www.oabcampinas.org.br. Acesso em: 23 abr. 2026.

PECK, P. Direito Digital. 7. ed. São Paulo: Saraiva Educação, 2021.

RENAUD, K.; WEIR, G. Cybersecurity and the unbearability of uncertainty. In: PROCEEDINGS OF THE HUMAN FACTORS AND ERGONOMICS SOCIETY ANNUAL MEETING, 2016.

SANTOS, V. M. dos; MOURA, L. F.; ZARELLI, P. R. Modelo diagnóstico de avaliação da governança de TI em universidades públicas federais. Revista de Administração Contemporânea, 2025.

SCF – SECURE CONTROLS FRAMEWORK COUNCIL. NIST CSF Tiers vs SCF Maturity Model. 2025. Disponível em: https://www.securecontrolsframework.com. Acesso em: 23 abr. 2026.

SILVA, K.; SARKIS, L. Análise de conformidade da LGPD nas instituições públicas de ensino superior no Brasil sob a perspectiva dos profissionais de TIC. In: WORKSHOP EM ENGENHARIA DE REQUISITOS, 2023. Anais [...]. 2023.

ZAKHAROVA, Y.; PARTYKA, A. The evolution of cyber risk management through the prism of the NIST cybersecurity framework. Cybersecurity: Education, Science, Technique, v. 30, 2025.